

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 2025 to August 2025. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

As an e-commerce business, all customer data, product listings, and transactional records reside within the database. Any compromise could:

- *Halt business operations (downtime of website and applications).*
- *Expose sensitive customer data, risking GDPR/PCI-DSS violations.*
- *Result in unauthorized changes to inventory or pricing.*
- *Cause reputational harm and loss of customer trust.*

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Competitor	Threat source compromises the integrity of information in such a	3	3	9

	way that prevents the business from carrying out critical operations.			
<i>Competitor</i>	Threat source alters or deletes data that is critical to day-to-day business operations.	3	3	9
<i>Hacker</i>	Threat source alters or deletes data that is critical to day-to-day business operations.	2	3	6
Employee	Threat source alters or deletes data that is critical to day-to-day business operations.	1	3	3

Approach

Threat actors could exploit the public exposure of the database to:

- Modify pricing or delete product images, disrupting daily operations.
- Steal sensitive customer or financial data, leading to compliance violations.
- Completely erase the database, halting all e-commerce operations.
- Insider or ex-employees could misuse legitimate access for malicious purposes.

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database which would make the website listing not accessible.

Implement daily database backups stored securely offsite.